

AAA Digital Platform — Technical Setup Guide

Version 2.0 · 11 May 2026 · Ambitious about Autism

Developer and DevOps reference for setup, deployment, and operation of the AAA Digital Platform.

Changes since v1.0: Added Eventbrite cohort integration env vars, brand-asset upload notes, and an updated CSP table that reflects the May 2026 client-direct Blob upload changes. Removed the `ENABLE_OAUTH_SSO` env variable — OAuth is now toggled in the admin UI (`OAuthSsoConfig` table).

1. Architecture Overview

Layer	Technology	Hosted at
Frontend & API	Next.js 14 App Router, TypeScript	Vercel (<code>asd-training-app-v2</code>)
Database	PostgreSQL, Prisma ORM	Neon (pooler port 6543)
Authentication	NextAuth v4 JWT sessions, TOTP MFA	In-app
File storage	Vercel Blob	Vercel
AI features	Vercel AI Gateway → Gemini / Claude / GPT	Vercel
Text-to-speech	ElevenLabs API (Lily voice, cached to Blob)	ElevenLabs
Email	Resend API (transactional)	Resend
Payments	Stripe (<code>ENABLE_PAYMENTS=false</code> in prod by default)	Stripe
Cohort import (optional)	Eventbrite	Eventbrite

Route groups: `(auth)` → public login / register / reset; `(dashboard)` → leaf roles; `(org-admin)` → `ORG_ADMIN`; `(super-admin)` → `SUPER_ADMIN` / `CHARITY_EMPLOYEE`; `(mfa)` → MFA flow; `(change-password)` → forced change.

Auth flow: credentials / OAuth / SAML → JWT callback extends token (`id` , `role` , `organisationId` , `mustChangePassword` , `totpEnabled` , `mfaPending` , `hasPassword` , `effectivePrograms` , `charityPermissions` , `cvBuilderEnabled` , `careersAdvisorEnabled` , `isParentOrg`) → session callback → middleware checks role / MFA / password.

2. Prerequisites

Tool	Version	Purpose
Node.js	18+ (20 LTS recommended)	Runtime
npm	9+	Package management
Git	Any recent version	Source control
Stripe CLI	Latest	Local webhook forwarding (optional)
Playwright	Installed via npm	E2E testing

External service accounts required: Vercel, Neon, GitHub, Resend, ElevenLabs. **Optional:** Google Cloud (Google SSO), Azure AD (Microsoft SSO), Eventbrite (cohort import), Stripe (payments).

3. Repository Setup

```
git clone https://github.com/Hodgy007/asd-training-app.git
cd asd-training-app
npm install
```

Script	Command	Purpose
<code>dev</code>	<code>npm run dev</code>	Start dev server on <code>localhost:3000</code>
<code>build</code>	<code>npm run build</code>	<code>prisma generate</code> + Vitest + <code>next build</code>
<code>test</code>	<code>npm run test</code>	Run Vitest unit tests
<code>test:e2e</code>	<code>npm run test:e2e</code>	Run Playwright E2E tests
<code>prisma:push</code>	<code>npm run prisma:push</code>	Push schema to database

<code>prisma:studio</code>	<code>npm run prisma:studio</code>	Open Prisma Studio
<code>prisma:seed</code>	<code>npm run prisma:seed</code>	Seed demo users
<code>prisma:generate</code>	<code>npm run prisma:generate</code>	Regenerate Prisma client after schema changes
<code>handover:build</code>	<code>npm run handover:build</code>	Rebuild all handover PDFs from markdown sources

4. Key Directory Structure

Path	Purpose
<code>app/(auth)/</code>	Login, register, forgot-password, reset-password, welcome, sso-complete (all public)
<code>app/(dashboard)/</code>	Leaf-role pages (dashboard, training, cv-builder, careers-advisor, jobs, etc.)
<code>app/(org-admin)/</code>	Org admin pages (<code>/admin/*</code>)
<code>app/(super-admin)/</code>	Super admin pages (<code>/super-admin/*</code>)
<code>app/(mfa)/</code>	MFA setup and verify pages
<code>app/api/</code>	All API route handlers
<code>components/</code>	Shared React components
<code>lib/</code>	Server-side utilities, AI runner, auth helpers, RBAC, rate limit, sanitisers
<code>prisma/</code>	<code>schema.prisma</code> , <code>seed.ts</code>
<code>types/</code>	TypeScript type extensions (session, next-auth)
<code>middleware.ts</code>	Route protection, MFA enforcement, role redirects
<code>public/</code>	Static assets (logo, favicon)
<code>docs/guides/</code>	User-facing markdown guides (source of truth for handover PDFs)
<code>docs/handover/</code>	Handover PDFs + their markdown sources + build tooling
<code>scripts/</code>	Build/maintenance scripts (e.g. <code>build-handover-pdfs.mjs</code>)

5. Environment Variables

Critical: `DATABASE_URL` must use the Neon **pooler** URL (port 6543) in production. Using the direct URL (port 5432) will exhaust connection limits on serverless.

Variable	Required	Description
<code>DATABASE_URL</code>	Yes	Neon pooler — port 6543 with <code>?pgbouncer=true</code>
<code>DIRECT_URL</code>	Yes	Neon direct — port 5432, Prisma migrations only
<code>NEXTAUTH_SECRET</code>	Yes	32+ char random secret: <code>openssl rand -base64 32</code>
<code>NEXTAUTH_URL</code>	Yes	Production URL, no trailing slash
<code>AI_GATEWAY_API_KEY</code>	Yes	Vercel AI Gateway key (multi-provider AI)
<code>RESEND_API_KEY</code>	Yes	Transactional email
<code>BLOB_READ_WRITE_TOKEN</code>	Yes	Vercel Blob file storage
<code>ELEVENLABS_API_KEY</code>	Yes	Text-to-speech (Lily voice)
<code>EMAIL_LOGO_URL</code>	Optional	Override AAA logo URL in transactional emails
<code>GOOGLE_CLIENT_ID</code>	Optional	Google OAuth button hidden if absent
<code>GOOGLE_CLIENT_SECRET</code>	Optional	Google OAuth client secret
<code>AZURE_AD_CLIENT_ID</code>	Optional	Microsoft OAuth button hidden if absent
<code>AZURE_AD_CLIENT_SECRET</code>	Optional	Azure AD OAuth client secret
<code>AZURE_AD_TENANT_ID</code>	Optional	Use <code>common</code> for all account types
<code>DISABLE_MFA</code>	Optional	Set <code>true</code> to skip MFA enforcement (dev only)
<code>ENABLE_PAYMENTS</code>	Optional	Set <code>true</code> to expose <code>/courses</code> and Stripe checkout
<code>STRIPE_SECRET_KEY</code>	Payments	Stripe secret key (<code>sk_test_...</code> / <code>sk_live_...</code>)
<code>STRIPE_PUBLISHABLE_KEY</code>	Payments	Stripe publishable key
<code>STRIPE_WEBHOOK_SECRET</code>	Payments	Stripe webhook signing secret (<code>whsec_...</code>)

Note: The `ENABLE_OAUTH_SSO` env variable was removed in May 2026. OAuth providers are now toggled per-environment by a Charity Admin in `/super-admin/settings/sso` (DB-

backed `OAuthSsoConfig`). Setting `GOOGLE_CLIENT_ID` / `AZURE_AD_CLIENT_ID` makes the providers *available*; flipping the admin toggle makes them *active*.

Eventbrite credentials are configured per-organisation in the admin UI rather than via env vars — see `/super-admin/settings/eventbrite` .

```
# Pull env vars from Vercel (dev branch):
npx vercel env pull .env.local

# Pull production env vars:
npx vercel env pull .env.production --environment production --yes
```

6. Database Setup (Neon)

Two Neon branches are in use: **main** (production, endpoint `ep-blue-thunder-a88kb0cy`) and **dev** (development, endpoint `ep-lucky-cherry-a8toqlw5`). Local dev pulls the dev branch env vars via `npx vercel env pull .env.local` .

```
# Push schema changes to dev database:
npm run prisma:push

# Push schema to PRODUCTION:
npx dotenv-cli -e .env.production -- npx prisma db push

# Seed demo users:
npm run prisma:seed

# Seed training content:
npx tsx prisma/seed-training-content.ts
```

Warn: Always push schema to **BOTH** dev AND production when adding columns that are queried at runtime. Production will crash if it references a missing column.

Prisma accessor gotchas:

- The CV model accessor is `prisma.cv` (not `prisma.cv`).
- Virtual classroom sessions use `prisma.classSession` (not `prisma.session` — that's the NextAuth Session table).

7. Local Development

```
npm run dev
# Server starts on http://localhost:3000

# Forward Stripe webhooks (separate terminal):
stripe listen --forward-to localhost:3000/api/stripe/webhook
```

Demo credentials (seeded by `npm run prisma:seed`):

Role	Email	Password
SUPER_ADMIN	<code>admin@asdawareness.org.uk</code>	<code>admin123</code>
EMPLOYEE	<code>demo@example.com</code>	<code>demo123</code>

Warn: The dev Neon branch may be paused after inactivity. If login fails with a database connection error, wake the branch up in the Neon console.

8. Testing

```
npm run test      # Vitest unit tests
npm run test:e2e  # Playwright E2E tests
npm run build     # Build (runs tests – failing test blocks deploy)
```

Test type	Location	What is tested
Vitest unit	<code>lib/__tests__/</code> and <code>app/api/.../__tests__/</code>	RBAC helpers, permission counts, job visibility logic, SCORM progress mapping, AI runner sentinels

Playwright E2E	<code>playwright-report/</code>	Full browser flows — login, training, admin
Build gate	<code>npm run build</code>	Vitest runs before <code>next build</code> — failure blocks deploy

Warn: Do NOT use `isomorphic-dompurify` or `jsdom` at runtime — they break on Vercel serverless. `jsdom` is a `devDependency` only (Vitest env). Use `sanitize-html` for HTML sanitisation.

9. Deployment (Vercel)

Vercel GitHub integration auto-deploys on push to `main` . Preview deployments are created for all branches.

```
# Deploy to production via git (preferred):
git push origin main

# Manual deploy (only if no git push was made):
npx vercel deploy --prod
```

Info: Never run `vercel deploy --prod` after a git push — Vercel auto-deploys from GitHub and a manual deploy creates a duplicate build.

Step	Action
1	Vercel detects push to <code>main</code>
2	Runs build command: <code>prisma generate && cross-env NODE_ENV=test vitest run && next build</code>
3	Deploys to production URL: <code>https://asd-training-app-v2.vercel.app</code>
4	Preview URL available for branch deploys

10. Content Security Policy

CSP is configured in `next.config.js` headers. Key directives that require explicit values:

Directive	Required values	Reason
<code>connect-src</code>	<code>vercel.com</code> , <code>blob.vercel-storage.com</code> , <code>*.public.blob.vercel-storage.com</code>	Client-direct Blob uploads (SCORM packages, brand-asset zips)
<code>media-src</code>	<code>blob:</code>	TTS audio playback
<code>frame-src</code>	<code>blob:</code>	SCORM iframe content
<code>script-src</code>	<code>self</code> , <code>unsafe-eval</code> (dev only)	Next.js HMR
<code>font-src</code>	<code>fonts.gstatic.com</code>	Google Fonts

Warn: SCORM iframe sandbox requires `allow-same-origin` . Removing it causes subresource requests to 401. Do not attempt to harden without a signed-URL scheme. (History: tried it, broke playback, reverted in commit `c317351` .)

11. Key Architectural Decisions

No PrismaAdapter. NextAuth uses JWT sessions (not database sessions) with manual SSO account linking in the `signIn` callback. This avoids `OAuthAccountNotLinked` errors and simplifies the auth flow.

`sanitize-html` , not `DOMPurify`. `isomorphic-dompurify` requires `jsdom` which breaks on Vercel serverless. `sanitize-html` is a pure-Node sanitiser with no browser dependencies.

SCORM buffering. The SCORM asset route (`/api/scorm/[lessonId]/[...path]`) buffers binary bodies before responding. Streaming corrupts media files — same issue as the TTS route.

TTS streaming, not redirect. The `/api/tts` route streams MP3 bytes directly rather than redirecting to Blob. This allows magic-byte validation and prevents browser cache collisions.

Neon over Supabase. Supabase was IPv6-only — incompatible with Vercel Lambda which uses IPv4. Neon supports both. Migration was completed in May 2026.

scorm-again v3. Handles both SCORM 1.2 (`window.API`) and SCORM 2004 (`window.API_1484_11`). Version 3 supports concurrent requests and improved CMI state management.

prisma.cv , not prisma.cv . Prisma generates accessors from model names. The CV model is named "CV" (uppercase) so the accessor is `prisma.cv` . Similarly `ClassSession` avoids collision with NextAuth `Session` .

OAuth toggled in DB, not env. `OAuthSsoConfig` lets Charity Admins flip Google / Microsoft on per-environment without a redeploy. Replaces the old `ENABLE_OAUTH_SSO` env flag (removed May 2026).

Auth-gated proxy routes for documents. Library, training, and job document URLs are never linked directly to Vercel Blob — every request goes through `/api/library/documents/[docId]/file` , `/api/scorm/[lessonId]/[...path]` , or `/api/jobs/[jobId]/attachments/[attachmentId]/file` . Lets us enforce per-user entitlement, rate-limit, and audit access.

12. Troubleshooting

Symptom	Likely cause	Fix
All <code>/api/auth/*</code> return 500	Wrong <code>DATABASE_URL</code> (direct, not pooler)	Use Neon pooler URL port 6543
Prisma client not found on Vercel	Client not regenerated before build	Build script must run <code>prisma generate</code> first
Login fails locally	Dev Neon branch paused	Wake branch in Neon console
Google SSO fails	Wrong redirect URI	Check Google Cloud Console → Credentials
Microsoft SSO fails	Wrong redirect URI or tenant	Check Azure Portal → App registrations
OAuth button missing from login page	Provider credentials set but admin toggle off	Sign in as Charity Admin → Settings → SSO → flip toggle
SCORM audio/video corrupted	Streaming not buffering	Ensure route buffers full body before response

TTS returns 200 but no audio	Non-MP3 response from ElevenLabs	Check <code>ELEVENLABS_API_KEY</code> ; inspect magic bytes
Welcome email never arrives	Resend domain not verified, or sender domain mismatch	Verify domain in Resend → Domains; check <code>lib/email-templates/layout.ts</code> From address
Build fails — test error	Vitest runs in build	Fix failing unit test before deploying
MFA redirect loop	TOTP not enrolled	Log in as admin, go to <code>/mfa-setup</code> , complete setup
Brand asset upload 413 / CSP block	CSP missing Blob hosts	Verify <code>connect-src</code> includes <code>vercel.com</code> + <code>*.public.blob.vercel-storage.com</code>
Self-registration form blocked	Rate limit (5 / 15 min / IP)	Wait or use a different IP